Qevra

SECURITY REVIEW REPORT

Plan 005 Smoke Test

Token

Bridge

ITERATION	REPORT DATE
1	8 Oct 2026
SOURCE	ADDRESS
Deployed contract Ethereum	0xa0b86991c6218b36c1d19d4a2e9eb0ce3606eb48
COMMIT	REVIEW PERIOD
Not set	8 Oct 2026 – 8 Oct 2026

Prepared by Qevra

01

Executive summary

CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL
1	1	0	0	0

Summary of project

02

Scope and version

SOURCE	Deployed contract
CHAIN	Ethereum
ADDRESS	0xa0b86991c6218b36c1d19d4a2e9eb0ce3606eb48
REVIEWED COMMIT	*Not set*
REVIEW PERIOD	8 Oct 2026 – 8 Oct 2026
CATEGORIES	Bridge
SCOPE	*Not set*

Files reviewed (0)

No file list was recorded for this iteration.

03

Findings

CODE	TITLE	SEVERITY	STATUS
QEV-01	MY TEST FINDING	Critical	Open
CEN-01	Owner Can Mint Tokens	High	Open

QEV-01

MY TEST FINDING

SEVERITY STATUS

Critical Open

DESCRIPTION

This is a description

RECOMMENDATION

This is a recommendation

CEN-01

Owner Can Mint Tokens

SEVERITY STATUS

High Open

LOCATIONS

`src/contracts/protocol/tokenization/AToken.sol:L57-L64`
— `mint` (restricted by `onlyPool`) can increase the token supply via `_mint`.
`src/contracts/protocol/tokenization/AToken.sol:L80-L85`
— `mintToTreasury` (restricted by `onlyPool`) can increase the token supply via `_mint`.
`src/contracts/protocol/tokenization/VariableDebtToken.sol:L64-L74`
— `mint` (restricted by `onlyPool`) can increase the token supply via `_mint`.

DESCRIPTION

A privileged account can create new tokens after deployment. Every mint dilutes existing holders, and an unlimited mint lets the privileged account sell newly created tokens into available liquidity, draining it. Holders must trust that this capability is never abused and that the key controlling it is never compromised.

`src/contracts/protocol/tokenization/AToken.sol`, lines 57–64:

```
  function mint(
    address caller,
    address onBehalfOf,
    uint256 amount,
    uint256 index
  ) public virtual override onlyPool returns (bool) {
    return _mintScaled(caller, onBehalfOf, amount, index);
```

```
    }
```

RECOMMENDATION

If the supply is meant to be fixed, mint it once in the constructor and remove the mint function. If ongoing minting is required, enforce a hard cap on total supply and a rate limit in the contract itself, and document the minting policy.

Reduce the trust users must place in the privileged role:

- Hold the role in a multi-signature wallet so that no single key can act alone.
- Route privileged actions through a timelock whose delay gives users time to react.
- Emit an event for every privileged change so it can be monitored.
- Remove the capability, or renounce the role, once it is no longer needed. Renouncing is irreversible and also removes the ability to respond to incidents.

04

Remediation status

SEVERITY	OPEN	RESOLVED	MITIGATED	ACCEPTED RISK	TOTAL
Critical	1	0	0	0	1
High	1	0	0	0	1
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	0	0	0	0	0
Total	2	0	0	0	2

Each finding's status appears in section 03, along with your team's response when one was recorded.

05

Severity definitions and limits

Severity definitions

Critical
Direct, repeatable loss of user or protocol funds, or complete loss of control over the system, reachable by an attacker under normal conditions.

High
Loss or freezing of funds, or a broken core invariant, under conditions an attacker can reach without unusual privilege or luck.

Medium
Meaningful damage under specific conditions: bounded loss, denial of service, or an assumption that fails outside normal operation.

Low
Real but limited issues — minor value leakage, edge-case failures, or defects that require improbable conditions to trigger.

Informational
No security impact in the current design. Clarity, maintainability, or hardening that reduces the chance of a future bug.

What this report does not claim

- A review covers the named scope at the pinned commit. Code merged afterwards is unreviewed.
- Findings are evidence of what was found. No review proves that nothing else exists.
- Formal verification proves specified properties and is a separate discipline; an audit does not imply it.
- Systems outside the agreed boundary are not assessed, even when they are adjacent to it.

This report states what was reviewed, at which version, and what was found. It is evidence of work performed within a named scope, not a certification of the system as a whole.